

Seguridad y roles de Sabnez Enterprise Platform

Modelo de acceso para SAP BTP y controles operativos

Audiencia Administración BTP, seguridad, RR. HH., finanzas y soporte

Versión documentada Sabnez RRHH 1.3.2 | 8 de septiembre de 2026

Propósito y alcance

Define scopes, colecciones, asignación recomendada y controles de XSUAA, CAP, archivos, correo y operación.

Resultado principal. La autorización se aplica en CAP; ocultar una aplicación o un botón no sustituye el control del backend.

Principios

- Mínimo privilegio y separación de funciones.
- Autogestión limitada a la identidad autenticada.
- Autorización en cada lectura, descarga, decisión y envío.
- Trazabilidad de cambios y decisiones.
- Secretos fuera del repositorio y del Centro de configuración.

Colecciones BTP

Colección	Plantilla	Uso
RRHH Editor	Editor	Crear y modificar empleados y documentos.
RRHH Admin	Admin	Eliminar y administrar parámetros.
Aprobaciones Admin	ApprovalAdmin	Delegaciones y operación de aprobaciones.
Tiempos Admin	TimeAdmin	Estructura, tiempos, Home Office y reportes.
Tiempos Finanzas	TimeFinance	Tarifas, costos, margen y finanzas.
Entregables Tiempos	TimeDeliverables	Generar entregables.
Cuentas de cobro RRHH	CollectionAccountHR	Expedientes y envío a contabilidad.

Roles adicionales

Plantilla	Asignación
TimeApprovalReassign	Solo soporte. La plantilla existe, pero falta una colección predefinida en el MTA.
CollectionAccountJob	Solo Job Scheduler; nunca usuarios humanos.
authenticated-user	Autogestión filtrada por identidad.

Perfiles recomendados

Perfil	Colecciones mínimas
Empleado	Ninguna administrativa.
Prestador	Ninguna administrativa.
RR. HH. operativo	RRHH Editor + Cuentas de cobro RRHH.
RR. HH. administrador	RRHH Editor + RRHH Admin + Cuentas de cobro RRHH.

Perfil	Colecciones mínimas
Comercial	Tiempos Admin.
Finanzas	Tiempos Finanzas; Tiempos Admin solo si administra estructura.
Aprobador	Autenticado; la tarea vigente define su decisión.
Administrador de aprobaciones	Aprobaciones Admin.
Soporte	TimeApprovalReassign temporal.

Acceso por servicio

Servicio	Requisito
AdminService	Editor; DELETE requiere Admin.
ConfiguracionService	Admin.
HomeOfficeAdminService	Editor y TimeAdmin.
TimeAdminService	TimeAdmin; economía requiere TimeFinance.
FinanceService	TimeFinance.
TimeReportingService	TimeAdmin; entregables requieren TimeDeliverables.
CollectionAccountService	Autenticado; RR. HH. requiere CollectionAccountHR.
Aprobaciones	Autenticado; reasignación requiere TimeApprovalReassign.
Autogestión	Autenticado y filtrado por identidad.

Archivos y datos sensibles

- Contratos, certificados médicos, liquidaciones, PILA y cuentas firmadas son confidenciales.
- La descarga debe validar empleado, proyecto o rol.
- No habilitar archivos pendientes o rechazados por antimalware.
- Validar tamaño, tipo real, nombre seguro y contenido.
- Evitar salarios, secretos y documentos completos en logs y correos.

Microsoft Graph

- Tenant, client y secret son credenciales técnicas.
- El correo de contabilidad es parámetro funcional, no secreto.
- Conceder solo permiso de envío desde el buzón autorizado.
- Rotar el secreto y vigilar su vencimiento.

Pendientes prioritarios

Prioridad	Acción
Alta	Crear colección para TimeApprovalReassign y limitarla a soporte.
Alta	Completar pruebas negativas de acceso cruzado.

Prioridad	Acción
Alta	Definir conservación de soportes médicos, PILA y contratos.
Media	Provisionar SAP_Notifications antes de habilitar Work Zone.
Media	Formalizar rotación de Microsoft Graph.
Media	Revisar trimestralmente las colecciones asignadas.